

Continuous External Trust Intelligence

A future-state report concept that extends proven certificate assessment into continuous Certificate Transparency, DNS and infrastructure change monitoring, vendor assurance, confidence scoring, tenant-scoped exploration, and governed remediation automation.

ILLUSTRATIVE FUTURE-STATE PRODUCT PREVIEW

Prepared by Vellitas, LLC

September 2026

CONFIDENTIAL - DESIGN PROTOTYPE - NOT A FRESH SECURITY ASSESSMENT

ILLUSTRATIVE ONLY

From periodic assessment to continuous trust monitoring.

The events and counts on this page are synthetic design examples. They show how the future report should communicate change without claiming that an anomaly proves compromise.

NEW CT ISSUANCES

04

Illustrative events requiring policy comparison.

DNS CHANGES

07

A, AAAA, CNAME, MX, or NS drift.

VENDOR EXCEPTIONS

02

Baseline deviations awaiting validation.

VERIFIED CLOSURES

11

Remediations confirmed from the outside.

FUTURE-STATE REPORTING PRINCIPLE

Executive question

What changed in the public trust surface, does it conflict with approved policy, how confident is the conclusion, who owns the next action, and has the corrective work been independently verified?

EARLY WARNING FROM PUBLIC CERTIFICATE ISSUANCE.

Continuous CT monitoring should identify related issuance before or independently of endpoint discovery, then correlate it with customer scope and approved infrastructure.

08:14 UTC	NEW ISSUANCE	api.example-corp.com	Unexpected issuer
-----------	--------------	----------------------	-------------------

08:18 UTC	SAN EXPANSION	*.payments.example-corp.com	New wildcard
-----------	---------------	-----------------------------	--------------

09:02 UTC	RENEWAL	www.example-corp.com	Approved pattern
-----------	---------	----------------------	------------------

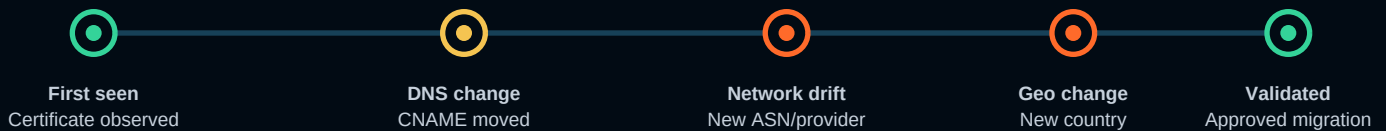
11:46 UTC	LOOKALIKE	examplecorp-support.net	Ownership unknown
-----------	-----------	-------------------------	-------------------

Production acceptance criteria

Deduplicate redundant CT sources; match exact, wildcard, SAN, subsidiary, brand, and reviewed similarity candidates; retain issuer, serial, validity, fingerprint, SPKI hash, log timestamp, source log, and first-seen evidence; suppress known renewals; assign confidence; and preserve reproducible evidence.

SHOW WHAT MOVED, WHEN, AND WHY IT MATTERS.

Correlate CT with DNS, IP, ASN, cloud provider, geography, and endpoint observations. The example below is synthetic.



Signals to preserve

A, AAAA, CNAME, MX, and NS; resolver and observation time; IP; ASN; network owner; provider; country; endpoint; certificate and key identity; first seen; last seen.

Context before escalation

Approved CDN, cloud migration, disaster recovery, acquisition, vendor, and maintenance patterns. Geography remains a risk signal, not a verdict.

Outcome

The report should explain the observed transition, compare it with customer policy, list corroborating evidence, record alternate legitimate explanations, assign confidence, and identify the validation step.

ONE CERTIFICATE CAN REVEAL A WIDER DEPLOYMENT PATTERN.

A future graph links certificate fingerprints and public keys to domains, endpoints, networks, locations, issuers, vendors, and historical observations.



Investigation value

Detect the same certificate or public key appearing on unfamiliar IP addresses, providers, vendor systems, or countries; identify blast radius after issuer or key incidents; and distinguish planned shared deployment from suspicious reuse.

A VENDOR'S PUBLIC EDGE BECOMES PART OF YOUR TRUST MODEL.

Continuous vendor assurance should apply a customer-approved baseline proportionate to the access, software, identity, data, or operational dependency involved.

ILLUSTRATIVE VENDOR PROFILE

Northstar Managed Services

Relationship: privileged remote administration | Criticality: high

● Certificate baseline	Pass	● TLS policy	Caution
● DNS drift	Investigate	● Approved geography	Pass

Minimum data model

Vendor, business service, access level, authorized scope, owner, criticality, required baseline, exceptions, last verification, findings, remediation owner, and retest status.

Assessment boundary

Passive public sources may identify exposure. Active scanning must remain within written authorization. Outside-in evidence does not replace the vendor's internal security program.

Standards alignment

Map the program to NIST CSF 2.0 GV.SC, NIST SP 800-161 Rev. 1, applicable contractual requirements, and sector-specific obligations. Referencing a standard does not itself establish compliance.

MAKE EVERY SCORE EXPLAINABLE.

A future finding should expose the evidence, policy, corroboration, legitimate alternatives, and validation step behind its confidence and severity.

SYNTHETIC EXAMPLE - HIGH PRIORITY

Certificate and DNS moved to an unapproved provider

New IP and ASN + new country + certificate fingerprint reused + DNS changed within 18 minutes + no approved maintenance record.



84 / 100

Evidence quality

Repeated direct observation

Policy conflict

Provider and country unapproved

Corroboration

Four independent changes

False-positive context

CDN / migration not yet ruled out

Required validation

Confirm change with owner

Severity is not confidence

Severity describes potential business impact. Confidence describes how strongly the evidence supports the working interpretation. A high-impact anomaly can still require customer validation before action.

GENERATE SCRIPTS, BUT KEEP HUMANS IN CONTROL.

Future remediation artifacts should be versioned, target-specific, reviewable, reversible, and verified from the outside. Automatic execution remains off by default.

01 Generate

Create a change artifact tied to a specific finding and target.

02 Preview

Show exact commands, expected effect, dependencies, and risk.

03 Dry run

Use a safe validation mode where the platform permits it.

04 Approve

Require authorized Vellitas and customer review.

05 Execute

Run through the customer's controlled change process.

06 Verify

Reobserve the endpoint and preserve result and rollback evidence.

Mandatory safeguards

Least privilege, tenant and target binding, immutable audit history, secrets isolation, output capture, rollback guidance, time-bounded approvals, customer change windows, and post-change external verification.

LET CUSTOMERS EXPLORE ONLY THEIR APPROVED PORTFOLIO.

The portal must deny access by default and bind every asset, observation, finding, report, script, and query to a tenant and confirmed scope.

ILLUSTRATIVE FILTERED SEARCH

Portfolio: Example Corp

Status: self-signed

Environment: public

Region: all

Owner: unassigned

Host	Finding	Confidence	Owner	State
vpn.example.com	Self-signed	Confirmed	Network	Open
admin.example.com	Default appliance cert	High	Unassigned	Triage
lab.example.com	Non-production exposed	Medium	Engineering	Exception

Scope onboarding

Start with customer-provided domains, brands, subsidiaries, acquisitions, networks, and cloud accounts. Propose related assets from public evidence for review; do not auto-authorize active assessment.

Access controls

Tenant-bound data model, RBAC, SSO/MFA, audit logging, export controls, reviewed support access, and authorization enforced below the interface at every query and object boundary.

BUILD ON THE PROVEN ASSESSMENT FOUNDATION.

The supplied report moves discovery and core certificate analysis into the current baseline. The remaining roadmap centers on continuous change, productized workflows, and safe customer access.

CURRENT**Established assessment**

Discovery, geospatial, name encroachment, CA inventory, certificate lifecycle, key/signature, protocol/cipher, wildcard, non-production, reporting, and consultant remediation.

NEXT**Normalize and monitor**

Evidence model; first/last seen; fingerprint/key reuse; expected-vs-observed policy; continuous CT; DNS/IP/ASN/provider correlation; confidence and alert suppression.

THEN**Workflow and portal**

Tenant-scoped search; candidate-scope review; SSO/MFA; ownership; tickets; retest; audit trail; vendor portfolios; SIEM/API/webhooks.

REPORTING STANDARD

Every future report must distinguish observed evidence, inferred interpretation, customer-confirmed context, current product capability, roadmap capability, severity, confidence, required work, responsible owner, and outside-in verification status.